NAME: THULASI S **ROLL:NO: 241901118**

EXP 4: DETECT SESSION HIJACKING

AIM:

To detect possible session hijacking by analysing network traffic and application logs using Wireshark and other security monitoring tools.

THEORY:

Since session hijacking (as seen in Experiment 3) usually relies on ARP spoofing or sniffing, most detection techniques focus on identifying:

1. ARP spoofing activity — abnormal or duplicate ARP replies on the network.
2. Duplicate/simultaneous sessions — the same session ID being used from two different IP addresses at the same time.
3. Unusual traffic patterns — sudden change in a session's source IP or User-Agent mid-session.

Detection can be done at two levels:

- Network level — using tools like Wireshark, Xarp, or arpwatch to detect ARP spoofing.
- Application level — using Intrusion Detection Systems (IDS) like Snort to flag suspicious session behavior.

TOOLS REQUIRED:

- Wireshark
- Xarp (ARP spoofing detection tool) or arpwatch
- Snort (optional, for IDS-based detection)
- The same lab setup from Experiment 3 (attacker performing ARP spoofing again, this time from the defender's point of view)

PROCEDURE:

Step 1: Detecting ARP Spoofing Using Wireshark

On the victim machine (or a monitoring machine), open Wireshark and capture traffic while the attack from Experiment 3 is repeated. Apply this filter:

```
arp.duplicate-address-detected
```

Wireshark automatically flags ARP replies that claim the same IP address is at two different MAC addresses — this is a strong sign of ARP spoofing.

You can also manually check the ARP table on the victim machine:

```
arp -a
```

If the gateway's IP address shows a MAC address that keeps changing between two different values every few seconds, that is a sign of ongoing ARP spoofing.

Step 2: Using Xarp for Real-Time ARP Spoof Detection

Install and run Xarp on the monitoring machine (Windows/Linux). Xarp continuously watches the ARP table and raises an alert the moment it sees:

- Two MAC addresses claiming the same IP
- A MAC address change for a previously known IP (like the gateway)

Take a screenshot of the alert generated when the Experiment 3 attack is repeated.

Step 3: Detecting Duplicate Sessions at the Application Level

If the lab web application (e.g., DVWA) has any session/audit logging enabled, check the server logs for:

- The same session ID (PHPSESSID) being used from two different source IPs
- A sudden change in browser User-Agent string within the same session

This can be simulated by checking Apache access logs:

```
tail -f /var/log/apache2/access.log
```

Look for the same session ID appearing with two different IP addresses in a short time window.

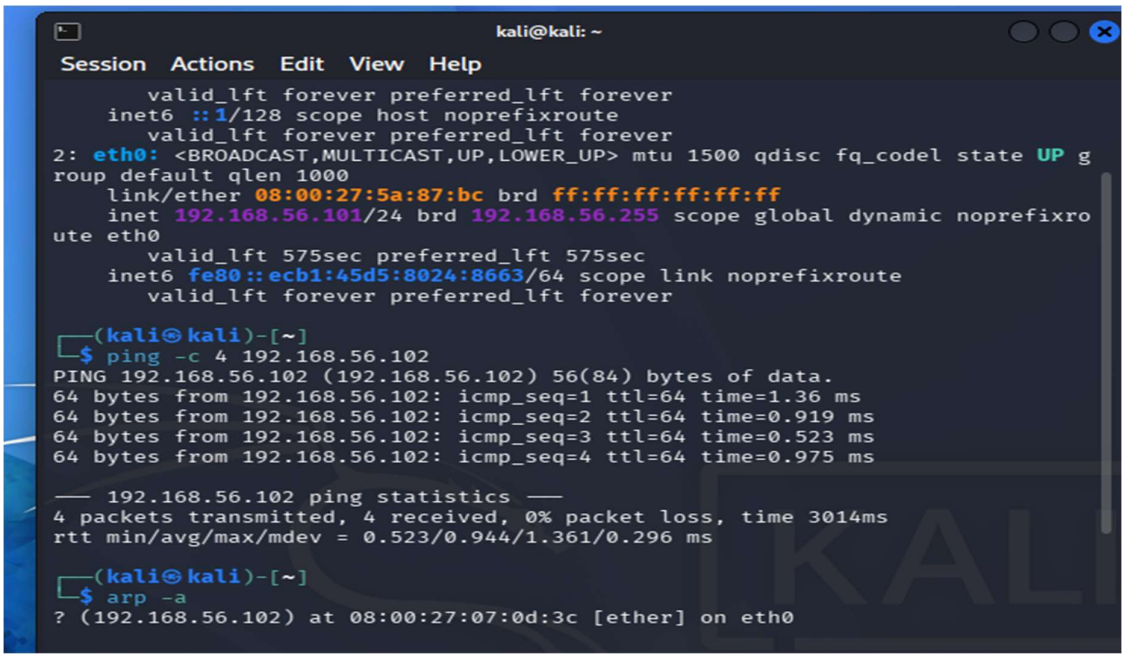
Step 4: Using Snort as an IDS (Optional)

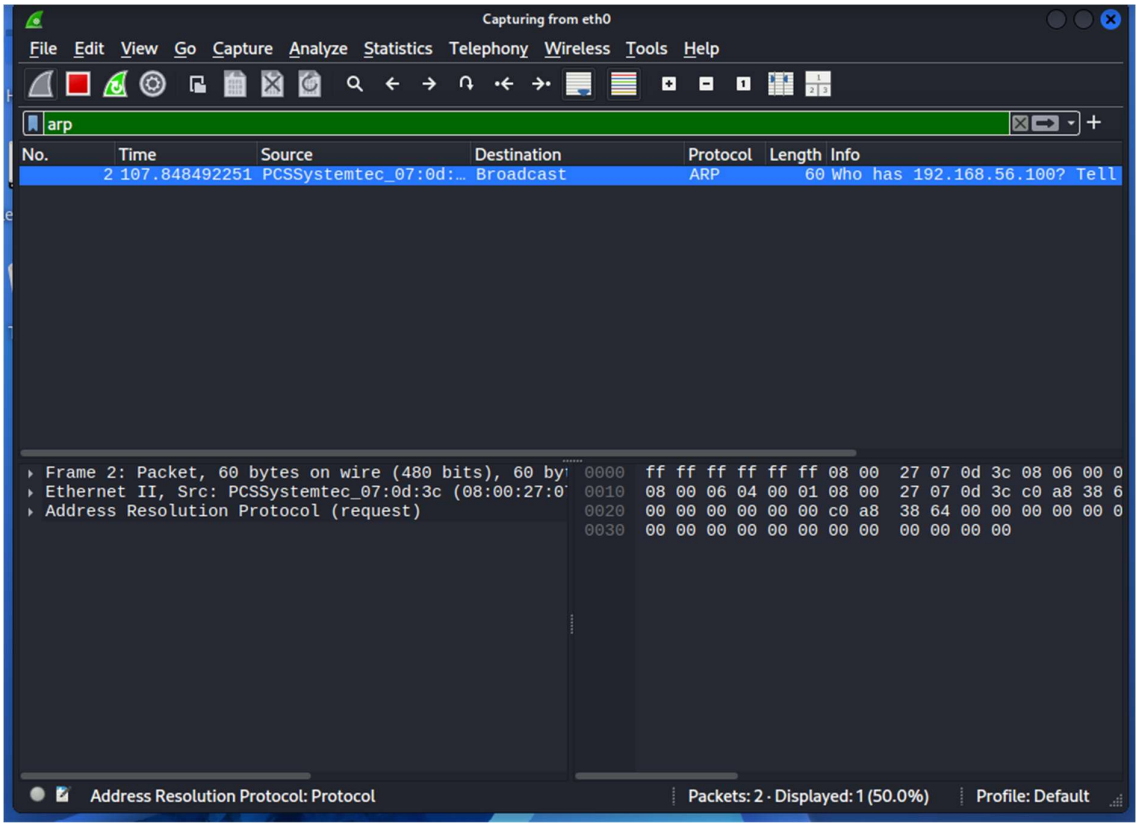
If Snort is installed, run it in IDS mode with the default ruleset and check for ARP spoofing / MITM alerts while the attack is repeated:

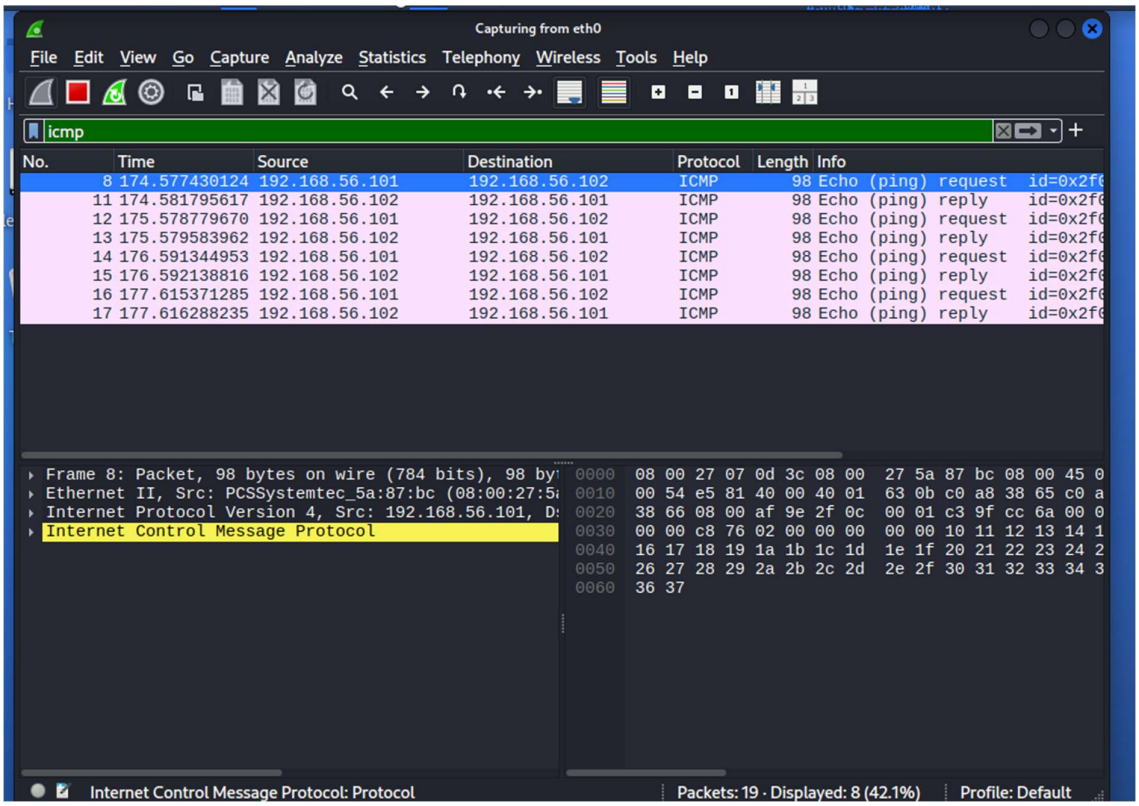
```
snort -A console -q -c /etc/snort/snort.conf -i eth0
```

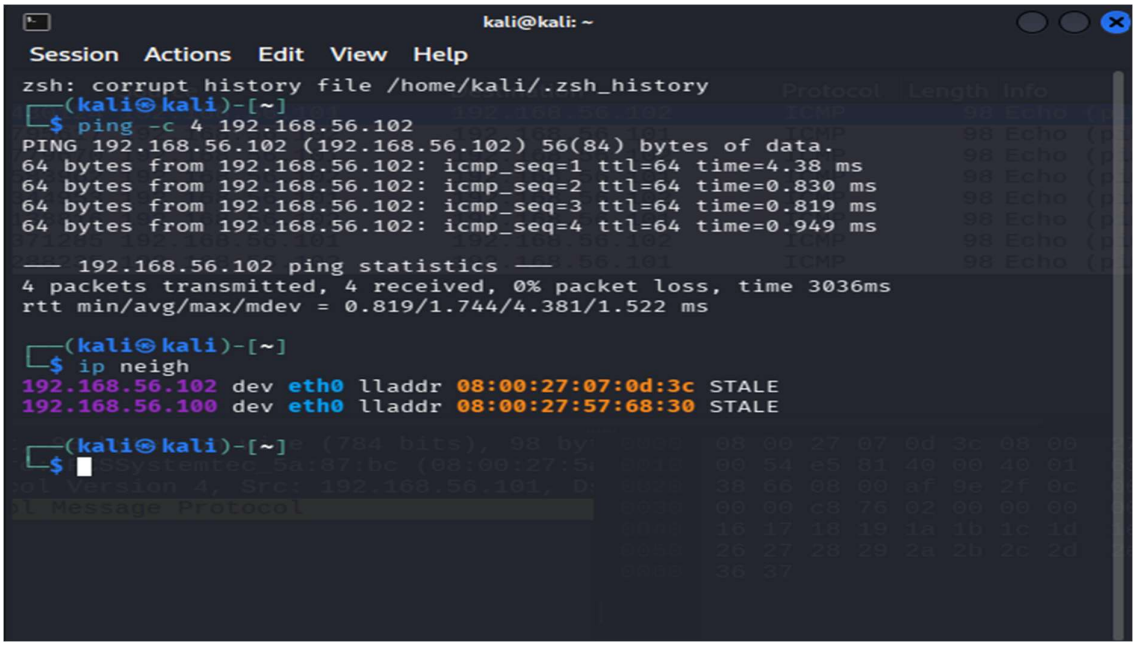
OBSERVATION:

TEST PPERFORMED	OBSERVATION
Checked IP addresses	Kali: 192.168.56.101; Metasploitable2: 192.168.56.102
Tested connectivity using ping	4 packets transmitted, 4 received, 0% packet loss.
Captured ARP packets using Wireshark	An ARP request asking for 192.168.56.100 was observed.
Analysed ICMP traffic	Echo requests and replies between Kali and Metasploitable2 were captured
Checked the ARP neighbour table using ip neigh	Metasploitable2 was mapped to MAC address 08:00:27:07:0d:3c, with state STALE.
Checked for session hijacking indicators	No confirmed ARP spoofing or session hijacking was observed in the collected evidence.




Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
arp
No. Time Source Destination Protocol Length Info
2 107.848492251 PCSSystemtec_07:0d:… Broadcast ARP 60 Who has 192.168.56.100? Tell
Frame 2: Packet, 60 bytes on wire (480 bits), 60 by
Ethernet II, Src: PCSSystemtec_07:0d:3c (08:00:27:0
Address Resolution Protocol (request)
0000 ff ff ff ff ff ff 08 00 27 07 0d 3c 08 06 00 0
0010 08 00 06 04 00 01 08 00 27 07 0d 3c c0 a8 38 6
0020 00 00 00 00 00 00 c0 a8 38 64 00 00 00 00 00 0
0030 00 00 00 00 00 00 00 00 00 00 00 00
Address Resolution Protocol: Protocol
Packets: 2 · Displayed: 1 (50.0%)
Profile: Default


Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
icmp
No. Time Source Destination Protocol Length Info
8 174.577430124 192.168.56.101 192.168.56.102 ICMP 98 Echo (ping) request id=0x2f
11 174.581795617 192.168.56.102 192.168.56.101 ICMP 98 Echo (ping) reply id=0x2f
12 175.578779670 192.168.56.101 192.168.56.102 ICMP 98 Echo (ping) request id=0x2f
13 175.579583962 192.168.56.102 192.168.56.101 ICMP 98 Echo (ping) reply id=0x2f
14 176.591344953 192.168.56.101 192.168.56.102 ICMP 98 Echo (ping) request id=0x2f
15 176.592138816 192.168.56.102 192.168.56.101 ICMP 98 Echo (ping) reply id=0x2f
16 177.615371285 192.168.56.101 192.168.56.102 ICMP 98 Echo (ping) request id=0x2f
17 177.616288235 192.168.56.102 192.168.56.101 ICMP 98 Echo (ping) reply id=0x2f
Frame 8: Packet, 98 bytes on wire (784 bits), 98 by
Ethernet II, Src: PCSSystemtec_5a:87:bc (08:00:27:5
Internet Protocol Version 4, Src: 192.168.56.101, D
Internet Control Message Protocol
0000 08 00 27 07 0d 3c 08 00 27 5a 87 bc 08 00 45 0
0010 00 54 e5 81 40 00 40 01 63 0b c0 a8 38 65 c0 a
0020 38 66 08 00 af 9e 2f 0c 00 01 c3 9f cc 6a 00 0
0030 00 00 c8 76 02 00 00 00 00 00 10 11 12 13 14 1
0040 16 17 18 19 1a 1b 1c 1d 1e 1f 20 21 22 23 24 2
0050 26 27 28 29 2a 2b 2c 2d 2e 2f 30 31 32 33 34 3
0060 36 37
Internet Control Message Protocol: Protocol
Packets: 19 · Displayed: 8 (42.1%)
Profile: Default



RESULT:

Network traffic was captured and analysed using Wireshark. Normal ARP requests and ICMP echo request/reply packets were observed. The ARP neighbour table was examined to understand IP-to-MAC address mapping and identify potential indicators of ARP spoofing. No session hijacking was confirmed during the observation.